GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules Submodule Name in GitPython

Report Type: Weekly · Generated: August 07, 2026 17:21 UTC · Coverage: Aug 07 - Aug 07, 2026

1 Total Advisories	0 Critical	1 High	0 Medium

HIGH Severity	N/A CVSS / Risk Score	TLP:CLEAR TLP Classification	PRO Customer Tier

Executive Summary

Summary GitPython computes the on-disk location of a submodule's separate Git directory (`.git/modules/<name>`) from the submodule's `.gitmodules` section name with no validation. Because that name is fully attacker-controlled content of a cloned repository, a malicious repository can set a submodule name to a traversal string (e.g. `../../../../home/victim/.something`) and cause GitPython to create and initialize a full Git repository at an attacker-chosen filesystem path outside the intended clone directory. The only precondition is that a victim clones the malicious repository with GitPython and runs submodule initialization (`submodule_update(init=True)` / `sm.update(init=True)`), a very common and often automatic step. Core Git itself already blocks this exact attack class (CVE-2018-11235), but GitPython's independent reimplementation never adopted an equivalent check. ### Details `src/GitPython/git/objects/submodule/util.py` `sm_name()` strips the `submodule "` / `"` wrapper

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
GitPython: Arbitrary Git Repository Creation Outside the Working Tree	HIGH		-	### Summary GitPython computes the on-disk location of a submodule's separat

MITRE ATT&CK® v15 Mapping

Technique density score: **0.0** · Techniques observed: **0** · Tactics covered: **0**

MITRE ATT&CK techniques pending analyst enrichment. Deploy detection rules from Section 6 to identify related activity.

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	-

Indicators of Compromise (IOCs)

IOC extraction for this advisory is pending enrichment pipeline completion. PRO subscribers receive real-time IOC push to SIEM/SOAR via the SENTINEL APEX webhook at: **GET /api/v1/intel/iocs?advisory={id}**. Full IOC packages include IPv4, domain, SHA256, and URL indicators with confidence scores, first-seen timestamps, and STIX 2.1 formatted bundles.

Detection Engineering

Deploy these production-ready detection rules into your SIEM platform to identify exploitation attempts in real time. Compatible with Microsoft Sentinel, Splunk ES, and any Sigma-compatible platform.

Sigma Rule - Webserver / Process Monitoring

```
title: SENTINEL APEX - CDB-ADVISORY Exploitation Attempt
id: cdb-cdb-advisory-det
status: experimental
description: Detects exploitation indicators related to CDB-ADVISORY.
references:
- https://intel.cyberdudebivash.com
author: CyberDudeBivash SENTINEL APEX
date: 2026/08/07
tags:
- attack.initial_access
- attack.t1190
logsource:
category: webserver
detection:
keywords:
- 'CDB-ADVISORY'
condition: keywords
falsepositives:
- Security testing / penetration testing
level: medium
```

Microsoft Sentinel - KQL Query

```
// SENTINEL APEX - GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules
Submodule Name in GitPython
// Advisory | Microsoft Sentinel KQL
let time_window = ago(24h);
SecurityAlert
| where TimeGenerated > time_window
| where Description has "GitPython: Arbitrary Git Repository Crea"
or AlertName has "GitPython: Arbitrary Git Repository Crea"
or ExtendedProperties has "GitPython: Arbitrary Git Repository Crea"
| extend Rule = "APEX-ADVISORY", Severity = "HIGH"
| project TimeGenerated, AlertName, AlertSeverity, Entities, Description, Rule, Severity
| order by TimeGenerated desc
```

Incident Response Playbook

Phase 1 - 0-24 Hours (Containment)

1. Activate IR team; assign lead analyst and executive sponsor.
2. Isolate or WAF-shield GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules Submodule Name in GitPython instances exposed to the internet.

3. Enable verbose access logging on all GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules Submodule Name in GitPython endpoints immediately.
4. Pull last 72h of web server and application logs for forensic baselining.
5. Check SENTINEL APEX IOC feeds and SIEM alerts for exploitation hits in your environment.
6. Notify relevant internal stakeholders and legal / compliance team.

Phase 2 - 24-72 Hours (Eradication)

1. Apply vendor patch for GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules Submodule Name in GitPython or implement recommended mitigation.
2. Deploy Sigma and KQL detection rules from Section 6 across all SIEM platforms.
3. Rotate all API keys, service account credentials, and session tokens.
4. Conduct forensic timeline reconstruction for potential compromise window.
5. Validate patch deployment across 100% of affected instances via asset inventory.

Phase 3 - 7 Days (Recovery & Hardening)

1. Conduct post-incident review and update incident response runbooks.
2. Threat hunt for lateral movement or persistence artifacts using MITRE ATT&CK mapping.
3. Update asset inventory with patched version information and closure evidence.
4. Submit findings to internal risk register and CISO dashboard.
5. Schedule follow-up vulnerability scan to confirm remediation completeness.

Financial Impact Analysis (FAIR Model)

$800K - $4.5M	$1.8M	$450K/day	$320K
Breach Cost Range (FAIR)	IBM Cost of Breach 2025 Median	Business Interruption Cost	Regulatory Fine Exposure

High severity incidents activate IR retainers, forensic investigation (avg 47 days), and reputational damage impacting 12-18% of revenue.

Remediation Cost Estimate: $180K · Includes engineering time, IR retainer activation, forensic investigation, and customer notification costs.

Regulatory & Compliance Implications

Organizations processing this advisory must evaluate obligations under applicable regulatory frameworks. The table below maps this threat to relevant compliance requirements.

Framework	Reference	Obligation
GDPR	Art. 32 / Art. 33	Appropriate technical measures; notify DPA if personal data affected

Framework	Reference	Obligation
PCI-DSS v4.0	Req. 6.3.3	Patches within 1 month; documented risk acceptance if deferred
NIS2 Directive	Art. 21	Risk management measures including vulnerability handling policies
NIST CSF 2.0	RS.MI / RC.RP	Incident mitigation and recovery planning; post-incident review

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules Submodule Name in GitPython.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK techniques.
4. Apply vendor patch for GitPython: Arbitrary Git Repository Creation Outside the Working Tree via Unvalidated .gitmodules Submodule Name in GitPython immediately - check NVD for official fix guidance.
5. Enable enhanced logging and alerting on all systems running affected software versions.
6. Deploy the Sigma detection rule from this report into your SIEM platform (Sentinel / Splunk / Elastic).
7. Audit all internet-facing instances of affected products and confirm patch deployment.

Appendix - Report Metadata & Legal

Field	Value
Report ID	intel--b7d749380429bde8637c8d44
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v166.0 GOD-MODE
Generated At	2026-08-07T17:21:40.79059
Customer Tier	PRO
Customer Email	-
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice